FIT FOR SURGERY

Phase 1 MVP — API Reference

Proposed REST API inventory mapped to the supplied Software Requirements Specification (SRS)

Patient PWA • Doctor Portal • Admin Portal • NestJS Backend

Important: The SRS describes required capabilities, not fixed URL paths. The routes in this document are proposed endpoint names to help implementation planning; they are not claimed to be mandated by the SRS.

Scope: Phase 1 MVP only

How to use this document

This reference consolidates the API routes previously listed for the Fit for Surgery Digital Prehabilitation Platform. HTTP methods and paths are proposals. Confirm the final contract with the client and clinical stakeholders before implementation, especially for validation rules, alert thresholds, report calculations, and consent handling.

Route conventions: `:patientId`, `:doctorId`, `:exerciseId`, `:categoryId`, `:notificationId`, and `:tokenId` are path parameters. Use authenticated identity for `/me` routes rather than trusting a client-supplied user ID.

Suggested baseline: prefix routes with `/api/v1`; require authentication except for the configured sign-in/provider flows; enforce role-based access control (RBAC) and patient-level isolation on the backend.

A. Authentication and user management

Auth / identity

Method	Endpoint	Purpose / notes
GET	`/api/v1/auth/me`	Return authenticated user identity and role.
POST	`/api/v1/auth/verify-email`	Optional backend endpoint if email verification is handled by the backend; Firebase/Auth0 may provide this flow.
POST	`/api/v1/patients`	Doctor registers a patient.
POST	`/api/v1/doctors`	Admin registers a doctor.
POST	`/api/v1/admins`	Admin provisioning endpoint; restrict to a secure, authorized provisioning flow.

Profiles

Method	Endpoint	Purpose / notes
GET	`/api/v1/users/me/profile`	Get the current user's basic profile.
PATCH	`/api/v1/users/me/profile`	Update the current user's basic profile.
GET	`/api/v1/patients/me/medical-profile`	Get the current patient's medical profile.
PATCH	`/api/v1/patients/me/medical-profile`	Update the current patient's medical profile.

B. Patient and doctor management

Patient management

Method	Endpoint	Purpose / notes
GET	`/api/v1/patients`	List patients visible to the authenticated doctor/admin, according to permissions.
GET	`/api/v1/patients/:patientId`	Get a patient's details, only when the caller is authorized.
PATCH	`/api/v1/patients/:patientId`	Update permitted patient fields.

Doctor management

Method	Endpoint	Purpose / notes
GET	`/api/v1/doctors`	List doctors for authorized admin workflows.
GET	`/api/v1/doctors/:doctorId`	Get doctor details.
PATCH	`/api/v1/doctors/:doctorId`	Update permitted doctor fields.

C. Exercise library and assigned plans

Exercise library

Method	Endpoint	Purpose / notes
GET	`/api/v1/exercise-categories`	List exercise categories: walking, strength, breathing, stretching.
GET	`/api/v1/exercises`	List exercises visible to the caller; patient visibility must be restricted to assigned exercises where applicable.
POST	`/api/v1/exercises`	Create an exercise (authorized admin).
GET	`/api/v1/exercises/:exerciseId`	Get exercise details subject to role and assignment rules.
PATCH	`/api/v1/exercises/:exerciseId`	Update an exercise (authorized admin).
DELETE	`/api/v1/exercises/:exerciseId`	Delete or deactivate an exercise (authorized admin; confirm deletion policy).

Patient exercise plans

Method	Endpoint	Purpose / notes
GET	`/api/v1/patients/me/exercise-plan`	Patient views their assigned plan.
GET	`/api/v1/patients/:patientId/exercise-plan`	Authorized doctor views the patient's assigned plan.
PUT	`/api/v1/patients/:patientId/exercise-plan`	Authorized doctor assigns or replaces/modifies the patient's plan.

D. Exercise completion and compliance

Completion tracking

Method	Endpoint	Purpose / notes
POST	`/api/v1/exercise-completions`	Record a completion for an exercise in the patient's assigned plan.
GET	`/api/v1/patients/me/exercise-completions`	Patient views their exercise history.
GET	`/api/v1/patients/:patientId/exercise-completions`	Authorized doctor views the patient's exercise history.
GET	`/api/v1/patients/:patientId/exercise-compliance`	Return compliance summary for an authorized doctor.

E. Daily health monitoring

Patient health records

Method	Endpoint	Purpose / notes
POST	`/api/v1/health-records`	Patient submits a manual health/activity record.
GET	`/api/v1/health-records/me`	Patient views historical records.
GET	`/api/v1/health-records/me/latest`	Patient views latest available readings.
GET	`/api/v1/health-records/me/trends`	Patient views historical trends.

Doctor review

Method	Endpoint	Purpose / notes
GET	`/api/v1/patients/:patientId/health-records`	Authorized doctor views patient health history.
GET	`/api/v1/patients/:patientId/health-records/latest`	Authorized doctor views latest readings.
GET	`/api/v1/patients/:patientId/health-records/trends`	Authorized doctor views health trends.

F. Dashboards, analytics, and patient timeline

Patient dashboard / timeline

Method	Endpoint	Purpose / notes
GET	`/api/v1/patients/me/dashboard`	Daily health summary, assigned tasks, progress, health status summary, and recent notifications.
GET	`/api/v1/patients/me/timeline`	Patient's chronological timeline.
GET	`/api/v1/patients/:patientId/timeline`	Authorized doctor views the patient's chronological timeline.

Analytics

Method	Endpoint	Purpose / notes
GET	`/api/v1/analytics/overview`	Clinical/admin overview; exact role access depends on the portal.
GET	`/api/v1/patients/:patientId/analytics`	Patient-level analytics for an authorized clinician.
GET	`/api/v1/analytics/exercise-compliance`	Exercise compliance analytics.
GET	`/api/v1/analytics/daily-activity`	Daily activity summary.
GET	`/api/v1/analytics/health-improvement`	Health improvement indicators; calculation needs clinical/product confirmation.

G. Notifications and reminders

Notifications

Method	Endpoint	Purpose / notes
GET	`/api/v1/notifications/me`	List notifications for the authenticated user.
PATCH	`/api/v1/notifications/:notificationId/read`	Mark a notification as read, after ownership/authorization checks.
POST	`/api/v1/devices/push-tokens`	Register a device/browser push token if needed for Firebase Cloud Messaging.
DELETE	`/api/v1/devices/push-tokens/:tokenId`	Remove a previously registered push token.

H. Reports

Patient reports

Method	Endpoint	Purpose / notes
GET	`/api/v1/patients/me/reports/weekly`	Patient weekly report.
GET	`/api/v1/patients/me/reports/monthly`	Patient monthly report.
GET	`/api/v1/patients/me/reports/exercise-compliance`	Patient exercise compliance report.
GET	`/api/v1/patients/me/reports/vital-trends`	Patient vital trend report.

Doctor reports

Method	Endpoint	Purpose / notes
GET	`/api/v1/patients/:patientId/reports/weekly`	Authorized doctor retrieves weekly patient report.
GET	`/api/v1/patients/:patientId/reports/monthly`	Authorized doctor retrieves monthly patient report.
GET	`/api/v1/patients/:patientId/reports/exercise-compliance`	Authorized doctor retrieves exercise compliance report.
GET	`/api/v1/patients/:patientId/reports/vital-trends`	Authorized doctor retrieves vital trend report.

I. Consent and privacy

Consent

Method	Endpoint	Purpose / notes
GET	`/api/v1/consents`	List current consent documents, privacy policy, and research consent options.
POST	`/api/v1/consents/acceptances`	Record a user's acceptance of a consent document.
GET	`/api/v1/consents/acceptances/me`	View consent acceptances for the authenticated user.

J. Admin exercise categories and dashboard

Admin

Method	Endpoint	Purpose / notes
POST	`/api/v1/exercise-categories`	Create an exercise category (authorized admin).
PATCH	`/api/v1/exercise-categories/:categoryId`	Update an exercise category (authorized admin).
DELETE	`/api/v1/exercise-categories/:categoryId`	Delete/deactivate a category (authorized admin; confirm deletion policy).
GET	`/api/v1/admin/dashboard`	Admin dashboard analytics.

K. Basic patient alerts

Alert review

Method	Endpoint	Purpose / notes
GET	`/api/v1/patients/:patientId/alerts`	Authorized doctor reviews basic alerts for a patient. Thresholds, severity, acknowledgement, and escalation rules require stakeholder confirmation.

Health data covered by the SRS

The daily monitoring API should support the SRS-listed manual-entry fields: blood pressure, pulse, SpO■, temperature, weight, optional blood sugar, pain score, walking duration, manual step count, sleep duration, nutrition intake, water intake, and mood assessment. Store historical records and provide trend views. Confirm the exact field schema, units, validation ranges, and whether a single request can contain multiple readings.

Authentication and authorization rules

• Require authenticated access for protected routes.

• Enforce role-based permissions in the backend, not only in frontend navigation.

• Derive patient identity from the authenticated session for /me endpoints; do not trust a patient ID supplied by the client to establish identity.

• Doctors may access only patients linked/assigned to them; deny unrelated patient access.

• Patients may view only their own health records, exercise plan, completions, timeline, reports, notifications, and consent history.

• Patients must not receive the full exercise library if the SRS says they should see only assigned exercises.

• Record appropriate audit events for sensitive access and changes, based on the agreed security design.

Not included in the strict Phase 1 SRS inventory

Do not add APIs for high-risk patient identification, a surgery-readiness score, HIS/EMR/EHR integration, future medical-device integrations, video calling, or chat unless a formally approved scope change adds them. These are out of scope for Phase 1 in the supplied SRS.

Decisions to confirm before implementation

• **Database:** the SRS mentions PostgreSQL/MySQL, while the separate Health Monitoring API Review mentions MongoDB. Confirm one database and update all documents before schema work.

• **Identity provider:** decide whether Firebase Authentication/Auth0 handles login, password reset, and email verification, or whether any of these flows are backend-owned.

• **Clinical thresholds:** the SRS depends on client-provided alert thresholds; do not invent medical limits or severity rules.

• **Metric formulas:** define compliance percentage, weekly/monthly rollups, and health-improvement indicators with the product/clinical team.

• **Time zones and idempotency:** define day boundaries, duplicate-write handling, and edit/delete policy for health records before implementing writes and rollups.

• **Consent lifecycle:** confirm document versions, withdrawal rules, and retention requirements if they are needed beyond basic acceptance tracking.

Suggested implementation priority

Priority	Implement
P0	Authentication, RBAC, doctor/admin patient registration, profiles, patient-level isolation.
P1	Exercise library and assignment, completion tracking, manual health records, history and trends.
P2	Doctor patient list, timeline, dashboard/analytics, basic alert review, reports.
P3	Reminders/push notifications, consent acceptance, admin analytics, hardening and deployment.

Document status: planning reference. It is not a finalized OpenAPI/Swagger contract. Request/response schemas, error codes, pagination, validation, idempotency, and exact permission matrix should be documented before implementation.